DEPI SOFTWARE TESTING TRACK — FINAL PROJECT

Requirement Gathering

Stakeholder Analysis, User Stories, Functional & Non-Functional Requirements, Business Rules, and Technical Standards

Project	Banking Transaction System	**Document**	Requirement Gathering
Prepared By	Muhammad Sayyid (Tech Lead)	Reviewed By	Project Team

Part 1. Stakeholder Analysis

A stakeholder is any individual, role, or standard that affects the system or is affected by its operation. Each stakeholder is rated by Influence (authority to change project scope or direction) and Interest (concern regarding project outcomes).

Stakeholder	Interest in the System	Influence	Interest	Engagement Strategy
Instructor (DEPI Software Testing Track)	Assesses deliverables, requirement traceability, adherence to testing standards, and final demonstration quality.	**High**	**High**	Manage Closely: Conduct structured milestone reviews, obtain formal sign-offs, and escalate scope or ambiguity questions early.
Project Team (5 Members)	Designs, develops, tests, reviews, and documents the complete full-stack banking application within the 8-week schedule.	**High**	**High**	Manage Closely: Enforce the peer-review matrix, hold weekly sync and risk meetings, and track all tasks via Jira and GitHub PRs.
QA & Test Automation Engineers (Team)	Verify business rules, execute manual (EP, BVA, Decision Tables) and automated (JUnit 5, Postman, Selenium) test suites, and log defects.	**High**	**High**	Manage Closely: Maintain 100% testable acceptance criteria, frozen DOM element IDs, deterministic seed data, and full RTM coverage.
Customers (Simulated End Users)	Register, manage Savings/Checking/Fixed Deposit accounts, execute deposits, withdrawals, and transfers, and export statements.	**Medium**	**High**	Keep Satisfied: Represent all customer journeys via clear user stories, transparent fee quotes, field-level validation, and responsive UI.
Bank Administrators (Simulated)	Monitor bank-wide reserves and daily metrics, search customer records, freeze/unfreeze suspicious accounts, and inspect audit logs.	**Medium**	**High**	Keep Satisfied: Provide dedicated administrative stories, strict role separation (least privilege), and comprehensive audit trails.
Security Expectations (OWASP Practice)	Protect customer accounts, personal data, and financial balances against unauthorized access, tampering, or leakage.	**Medium**	**High**	Keep Satisfied: Embed security requirements SEC-01 through SEC-11 into architecture design, code reviews, and security test suites.

Stakeholder	Interest in the System	Influence	Interest	Engagement Strategy
Published Market Figures (Central Bank, InstaPay, Local Banks)	Provide realistic reference benchmarks for EGP transfer fees, account minimums, daily limits, and savings interest rates.	**Low**	**Medium**	Monitor: Externalize all rates, fees, and limits in application configuration (application.yml) and verify figures prior to final demo.

1.1 Power and Interest Grid

Interest \ Influence (Power)	High Influence (Power)	Low Influence (Power)
High Interest	Manage Closely: • Instructor (DEPI Track) • Project Team (5 Members) • QA & Test Engineers Action: Report progress at every milestone, conduct peer reviews, and secure written approval of requirements.	Keep Satisfied: • Customers (Simulated End Users) • Bank Administrators (Simulated) • Security Expectations (OWASP) Action: Ensure user stories, acceptance criteria, and security rules (SEC-01 to SEC-11) comprehensively cover their needs.
Low Interest	Keep Informed: • (No stakeholder falls in this quadrant for the current project scope)	Monitor: • Published Market Figures (Central Bank, InstaPay, Banks) Action: Store rates, limits, and fee parameters in configuration files and re-verify before the final demonstration.

Note on Simulated Stakeholders: Customers and bank administrators do not exist as live production users during this project. Instead, they are faithfully represented through user stories, acceptance criteria, and pre-configured test accounts in the development seed data so that every requirement can be deterministically verified by testers.

Part 2. User Stories

Each story follows the standard Agile template: 'As a <role>, I want <goal>, so that <benefit>'. Acceptance criteria define the testable conditions of satisfaction. Every story links directly to Functional Requirements (Part 3), Business Rules (Part 5), and assigned module owners.

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-01	As a Visitor, I want to register as a customer with my name, email, phone, and password, so that I can open a bank account.	**Must**	Valid data creates a login credential and a customer profile atomically. A duplicate email (case-insensitive) is refused with error code DUPLICATE_EMAIL. Weak passwords or invalid fields show clear validation messages.	AUTH-01, AUTH-05, CUS-02, BR-24	Asmaa Mohamed (UI) & Muhammad Sayyid (Auth)
US-02	As a Customer, I want to log in and log out with my email and password, so that my accounts remain private.	**Must**	Correct credentials redirect to the customer dashboard and renew the session ID. Wrong credentials display a single generic message ('Invalid email or password'). Logout invalidates the session immediately.	AUTH-02, AUTH-03, SEC-03	Asmaa Mohamed (UI) & Muhammad Sayyid (Auth)
US-03	As a Customer, I want my account login to be locked for 15 minutes after 5 consecutive wrong password attempts, so that attackers cannot brute-force my password.	**Should**	After 5 failed attempts, a 6th attempt (even with the correct password) is refused until 15 minutes have elapsed, while keeping the error message generic and writing a lockout entry to the audit log.	AUTH-06, SEC-03, SEC-09, AUD-01	Muhammad Sayyid

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-04	As a Customer, I want to be automatically logged out after 15 minutes of inactivity, so that nobody can use my unattended screen.	**Should**	After 15 minutes without server requests, the next navigation or form submission invalidates the session and redirects the user to the login page.	AUTH-07, SEC-06	Muhammad Sayyid
US-05	As a Customer, I want to view and edit my full name and phone number, so that my personal profile stays accurate.	**Must**	Valid name and phone changes are persisted immediately; email is displayed as read-only and cannot be modified; invalid formats display field-level error messages.	CUS-01, CUS-02	Aghapy Antonious
US-06	As a Customer, I want to see all my accounts and my total balance on a single dashboard page, so that I know my financial position at a glance.	**Must**	The dashboard lists every account owned by the customer showing account type, 12-digit account number, status (ACTIVE, FROZEN, CLOSED), and current balance. The total balance sums all non-closed accounts.	CUS-03	Aghapy Antonious

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-07	As a Customer, I want to open a Savings, Checking, or Fixed Deposit account, so that I can save, spend, or lock funds for higher returns.	**Must**	Opening deposit enforces type minimums (1,000 EGP Savings; 0 EGP Checking; 5,000 EGP Fixed Deposit with valid term). Generates a unique 12-digit account number with a valid Luhn check digit. Attempting to open a 6th non-closed account fails with MAX_ACCOUNTS_EXCEEDED.	ACC-01, ACC-02, ACC-03, ACC-06, BR-07, BR-09, BR-11, BR-12, BR-22, BR-23	Aladdin Ahmed
US-08	As a Customer, I want to deposit money into my active account, so that I can add funds to my balance.	**Must**	A valid positive amount (up to 2 decimal places, within single-deposit limit) increases the account balance and appends an immutable DEPOSIT ledger row. Zero, negative, >2 decimal amounts, or deposits into Fixed Deposit / non-active accounts are refused with specific error codes.	TXN-01, TXN-04, BR-01, BR-02, BR-04, BR-13, BR-20	Aladdin Ahmed

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-09	As a Customer, I want to withdraw money within my account rules and limits, so that I can access my funds safely.	**Must**	Savings balance cannot drop below 1,000.00 EGP (MIN_BALANCE_VIOLATION). Checking allows overdraft down to -1,000.00 EGP (OVERDRAFT_LIMIT_EXCEEDED). Per-transaction (70,000.00 EGP), daily (120,000.00 EGP), and monthly (400,000.00 EGP) withdrawal limits are strictly enforced.	TXN-02, TXN-04, TXN-06, TXN-07, BR-05, BR-06, BR-07, BR-10, BR-20	Aladdin Ahmed
US-10	As a Customer, I want to transfer money to another customer's account and see the calculated fee before confirming, so that I know the exact total debited.	**Must**	The confirmation screen displays destination account number, transfer fee (0.1%, min 0.50 EGP, max 20.00 EGP), and total debit (amount + fee). Execution atomically writes three ledger rows sharing one reference: source TRANSFER_OUT, destination TRANSFER_IN, and source FEE.	TXN-03, TXN-05, TXN-09, ACC-07, BR-26, BR-28, BR-29	Muhammad Sayyid

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-11	As a Customer, I want to transfer money between my own accounts without paying a fee, so that I can manage my balances for free.	**Must**	A transfer between two distinct ACTIVE accounts owned by the same customer charges 0.00 EGP fee, writes two ledger rows (TRANSFER_OUT and TRANSFER_IN) with no FEE row, and updates both balances atomically.	TXN-03, TXN-05, BR-27, BR-28	Muhammad Sayyid
US-12	As a Customer, I want to request a transfer fee quote from the API before executing a transfer, so that client applications can display the exact cost upfront.	**Should**	Calling the quote endpoint validates account numbers and returns the calculated fee and total debit amount in JSON without modifying any database balances or writing ledger entries.	TXN-09, BR-26, BR-27	Muhammad Sayyid
US-13	As a Customer, I want to safely retry a transfer or transaction without paying twice, so that a network glitch or double-click does not duplicate charges.	**Should**	Submitting two POST requests with the same Idempotency-Key header for the same operation executes the financial transaction only once and returns the identical response payload.	TXN-08, BR-19	Muhammad Sayyid

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-14	As a Customer, I want to view my account statement with the running balance after each operation, filter it, and export it to CSV, so that I can reconcile my finances.	**Must**	Statement displays transactions ordered newest first, paginated (default 10, max 100 per page), showing post-transaction balance. Filtering by date range and transaction type works accurately, and CSV export downloads a properly formatted file compatible with Excel.	STM-01, STM-02, STM-03, BR-17	Aghapy Antonious
US-15	As a Customer, I want to close an active account that has a zero balance, so that I can discontinue accounts I no longer use.	**Must**	Closing succeeds only when the account is ACTIVE and its balance is exactly 0.00 EGP (otherwise fails with NON_ZERO_BALANCE or ACCOUNT_NOT_ACTIVE). The closed account retains its historical statement but rejects all future operations.	ACC-04, BR-20, BR-21	Aladdin Ahmed
US-16	As a Customer, I want the system to block any attempt to view or operate on another customer's account, so that my financial data and funds are protected from IDOR attacks.	**Must**	Any UI or API request referencing another customer's account ID or number returns HTTP 404 (ACCOUNT_NOT_FOUND)—identical to a non-existent account—so account existence is never leaked.	AUTH-04, SEC-01, SEC-02	Muhammad Sayyid

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-17	As a Fixed Deposit holder, I want withdrawals blocked before maturity and full interest credited upon maturity, so that my term deposit earns the guaranteed return.	**Must**	Any withdrawal attempt before the maturity date fails with FD_NOT_MATURE. On or after maturity, total term interest is credited exactly once, partial withdrawals are refused, and a full withdrawal of principal plus interest succeeds.	TXN-02, JOB-02, BR-12, BR-14, BR-15	Aladdin Ahmed
US-18	As a Savings account holder, I want to receive monthly interest automatically, so that my savings grow without manual intervention.	**Should**	Each calendar month, every ACTIVE Savings account meeting the minimum balance receives an INTEREST ledger entry equal to (balance × 17% / 12) rounded HALF_UP, credited at most once per month.	JOB-01, BR-08	Muhammad Sayyid
US-19	As an Admin, I want to view a central dashboard showing total bank reserves, customer count, accounts breakdown, today's transactions, and today's fees, so that I can oversee bank operations.	**Must**	Dashboard figures accurately match live database aggregates (excluding closed accounts from reserves). Admin users have no personal bank accounts and cannot trigger money transfers.	ADM-01, ADM-07	Aghapy Antonious

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-20	As an Admin, I want to search customers by name, so that I can locate customer profiles and assist them quickly.	**Must**	A trimmed, case-insensitive partial name query (minimum 2 characters) returns all matching customers. A single-character or empty search query is refused with INVALID_SEARCH_QUERY.	ADM-02, BR-25	Aghapy Antonious
US-21	As an Admin, I want to freeze and unfreeze any customer account with a mandatory reason, so that I can halt suspicious financial activity immediately.	**Must**	Freezing an ACTIVE account changes its status to FROZEN and blocks all deposits, withdrawals, and transfers (ACCOUNT_FROZEN). Both freeze and unfreeze actions require a non-empty reason and write an immutable entry to the audit log.	ACC-05, BR-20, AUD-01	Aghapy Antonious
US-22	As an Admin, I want to view the system audit log filtered by date range, user, and action type, so that I can investigate security or operational incidents.	**Should**	Audit log displays registrations, failed logins, lockouts, account status changes, and failed/succeeded transactions with actor, timestamp, target, result, and client IP. Passwords or session tokens never appear.	ADM-05, AUD-01, AUD-02, SEC-11	Aghapy Antonious

ID	User Story	Priority	Acceptance Criteria	Requirement & Rule Links	Owner
US-23	As an Admin, I want to trigger the monthly savings interest calculation job manually, so that I can recover from a missed scheduled run or demonstrate interest posting.	**Should**	Triggering the job manually executes the savings interest logic and writes an audit entry. Running it multiple times within the same calendar month credits interest only once per eligible account (idempotent).	ADM-06, JOB-01, BR-08, AUD-01	Aghapy Antonious & Muhammad Sayyid
US-24	As an Admin, I want to identify the customer with the highest total balance and search accounts by type and balance range, so that I can generate executive reports.	**Should**	Richest customer query returns the top customer across non-closed accounts (listing all tied customers if balances are equal). Account search accurately filters by account number, type, minimum balance, and maximum balance.	ADM-03, ADM-04	Aghapy Antonious
US-25	As an Admin, I want the system to strictly prevent administrators from moving money or viewing password hashes, so that a compromised admin account cannot steal funds or credentials.	**Must**	All deposit, withdrawal, and transfer endpoints reject requests from ADMIN roles with HTTP 403 Forbidden. Password hashes are excluded from all DTOs, views, API responses, and log files.	ADM-07, AUTH-03, AUTH-08, SEC-01, SEC-08	Muhammad Sayyid

Summary of User Stories: 25 Total User Stories | Must Have: 17 Stories | Should Have: 8 Stories.

Part 3. Functional Requirements

A functional requirement specifies a deterministic behavior or service that the system must provide. Below are all 41 functional requirements of the Banking Transaction System, complete with MoSCoW priorities and bidirectional traceability to User Stories.

ID	Functional Requirement Specification	Priority	Serves Stories
AUTH-01	A visitor can register as a customer by providing full name, email, and password (phone number is optional). Registration atomically creates both the authentication login record and the customer profile.	**Must**	US-01
AUTH-02	Users log in with email and password and can log out at any time. The web interface uses stateful HTTP sessions; the REST API uses stateless HTTP Basic authentication.	**Must**	US-02
AUTH-03	Two distinct roles exist: CUSTOMER and ADMIN. Every web page and API endpoint enforces role authorization on the server via Spring Security filter chains. Hiding a UI button does not constitute security.	**Must**	US-02, US-25
AUTH-04	A customer can view and operate strictly on their own profile, accounts, statements, and transactions. Any cross-customer access attempt is denied (see SEC-02).	**Must**	US-16
AUTH-05	Passwords must be 8 to 64 characters long, containing at least one uppercase letter, one lowercase letter, and one digit, and are stored exclusively as salted BCrypt hashes.	**Must**	US-01
AUTH-06	After 5 consecutive failed login attempts for an email address, the account is locked for 15 minutes (BR-24). The login failure message is always generic: 'Invalid email or password'.	**Should**	US-03
AUTH-07	Authenticated web sessions automatically expire after 15 minutes of user inactivity, requiring re-authentication on the next request.	**Should**	US-04
AUTH-08	The initial administrator account is provisioned from environment variables on first application startup. Fixed demonstration credentials exist only when running under the 'dev' or 'test' profile.	**Must**	US-25
CUS-01	An authenticated customer can view and update their full name and phone number. The registered email address is read-only after registration.	**Must**	US-05
CUS-02	Profile validation rules: full name must be 2–50 characters (alphabetic letters, spaces, hyphens, apostrophes); email must be valid RFC format, up to 100 characters, and unique case-insensitively; phone is optional, 10–15 digits with an optional leading '+'.	**Must**	US-01, US-05
CUS-03	The customer dashboard displays all accounts owned by the customer (account type, 12-digit account number, current status, and balance) alongside the aggregate total balance across all non-closed accounts.	**Must**	US-06

ID	Functional Requirement Specification	Priority	Serves Stories
ACC-01	A customer can open a Savings, Checking, or Fixed Deposit account. The initial opening deposit must satisfy the type-specific rules (BR-07, BR-09, BR-11). Opening a Fixed Deposit also requires selecting a valid lock-in term (BR-12).	**Must**	US-07
ACC-02	The system automatically generates a unique 12-digit numeric account number composed of a database sequence prefix plus a Luhn check digit (BR-23). It never changes and is never reused.	**Must**	US-07
ACC-03	The account detail view displays all type-specific attributes: annual interest rate, minimum required balance (Savings), overdraft limit (Checking), lock-in term in months, and maturity date (Fixed Deposit).	**Must**	US-07
ACC-04	A customer can close an own ACTIVE account whose current balance is exactly 0.00 EGP (BR-21). A closed account retains all historical data and statement entries but permanently rejects any future financial or status operations.	**Must**	US-15
ACC-05	An administrator can freeze any ACTIVE account and unfreeze any FROZEN account. Every freeze or unfreeze action requires a non-empty text reason (up to 255 characters), which is recorded in the audit log (AUD-01).	**Must**	US-21
ACC-06	A customer may hold at most 5 non-closed accounts (ACTIVE or FROZEN combined) at any given time (BR-22). Any request to open a 6th open account is rejected with error code MAX_ACCOUNTS_EXCEEDED.	**Should**	US-07
ACC-07	Account numbers entered by users in transfer or search forms are validated for exact length (12 digits), numeric characters only, and a valid Luhn check digit before performing any database query.	**Should**	US-10
TXN-01	Deposit: A customer can deposit money into an own ACTIVE Savings or Checking account (simulating a cash deposit for demonstration purposes). Additional deposits into an existing Fixed Deposit account are prohibited (BR-13).	**Must**	US-08
TXN-02	Withdraw: A customer can withdraw money from an own ACTIVE account, subject to account-type balance rules (Savings minimum balance, Checking overdraft limit, Fixed Deposit maturity check) and withdrawal velocity limits.	**Must**	US-09, US-17
TXN-03	Transfer: A customer can transfer money from an own ACTIVE Savings or Checking account to any other ACTIVE account (own or another customer's) by specifying the 12-digit destination account number and an optional description (up to 100 characters). A transfer fee applies to transfers sent to another customer's account (BR-26), whereas transfers between a customer's own accounts are free of charge (BR-27).	**Must**	US-10, US-11
TXN-04	Every monetary operation writes immutable ledger entries containing transaction type, amount, running balance after transaction, counterparty account number, description, timestamp, and unique reference ID. A transfer writes two linked entries sharing the same reference ID (TRANSFER_OUT and TRANSFER_IN), plus a third FEE entry on the source account whenever a transfer fee applies (BR-29).	**Must**	US-08, US-09, US-10

ID	Functional Requirement Specification	Priority	Serves Stories
TXN-05	Every monetary operation is strictly atomic: either all balance updates and ledger entries succeed together within a single database transaction, or the entire operation rolls back leaving all balances unchanged.	**Must**	US-10, US-11
TXN-06	Concurrent monetary requests targeting the same account never corrupt balances, produce lost updates, or bypass minimum balance and daily/monthly withdrawal limits (see Part 6, Section 6.2).	**Must**	US-09
TXN-07	Every business rule or validation violation returns a deterministic machine-readable error code and a clear human-readable message (see Part 6, Section 6.1 for the complete Error Code Catalogue).	**Must**	US-09
TXN-08	Money-moving POST requests accept an optional 'Idempotency-Key' HTTP header (or hidden form token). Repeating a request with the same key within 24 hours returns the original result without executing the transaction twice.	**Should**	US-13
TXN-09	Before a transfer is executed on the web UI, a confirmation step displays the masked destination account holder name, destination account number, calculated transfer fee, and total debit (amount + fee). In addition, the REST API provides a dedicated quote endpoint that calculates and returns the fee and total debit without moving any money.	**Should**	US-10, US-12
STM-01	Account Statement: Displays ledger transactions for an account ordered newest first, showing the running balance after each entry, with server-side pagination (default 10 rows per page, maximum 100 rows per page).	**Must**	US-14
STM-02	Statement Filtering: Customers can filter their account statement by start date, end date, and transaction type (DEPOSIT, WITHDRAWAL, TRANSFER_IN, TRANSFER_OUT, FEE, INTEREST).	**Should**	US-14
STM-03	Statement CSV Export: Customers can export the currently filtered account statement as a downloadable UTF-8 CSV file with standard headers and safe formula-injection escaping.	**Should**	US-14
ADM-01	Admin Dashboard: Displays total bank reserves (sum of balances across all non-closed accounts), total registered customers, account counts grouped by type and status, count of transactions executed today, and total transfer fees collected today.	**Must**	US-19
ADM-02	Customer Search: Administrators can search customers by name using a trimmed, case-insensitive partial match requiring a minimum of 2 characters (BR-25).	**Must**	US-20
ADM-03	Account Search: Administrators can search and filter accounts by 12-digit account number, account type (SAVINGS, CHECKING, FIXED_DEPOSIT), account status, and balance range (minimum and maximum balance).	**Should**	US-24
ADM-04	Richest Customer Report: Identifies the customer holding the highest aggregate balance across all non-closed accounts. If multiple customers are tied for the highest total, all tied customers are returned.	**Should**	US-24

ID	Functional Requirement Specification	Priority	Serves Stories
ADM-05	Audit Log Viewer: Administrators can view system audit log entries ordered newest first, filtered by date range, actor email/ID, and action type.	**Should**	US-22
ADM-06	Manual Interest Trigger: Administrators can manually trigger the monthly savings interest calculation job. Execution is idempotent per calendar month so no account is credited twice in the same month (JOB-01).	**Should**	US-23
ADM-07	Separation of Duties (Least Privilege): Administrators cannot open personal bank accounts, cannot execute deposits, withdrawals, or transfers, and cannot view plaintext or hashed passwords.	**Must**	US-19, US-25
JOB-01	Monthly Savings Interest Job: Credits monthly interest to every ACTIVE Savings account meeting the minimum balance requirement, calculated as (balance × annual_rate / 12) rounded HALF_UP, posted as an INTEREST ledger transaction at most once per account per calendar month (BR-08).	**Should**	US-18, US-23
JOB-02	Fixed Deposit Maturity Job: On or after a Fixed Deposit account's maturity date, credits the full term interest (BR-15) as an INTEREST ledger transaction exactly once and marks the deposit as matured for full withdrawal.	**Should**	US-17
AUD-01	Security & Financial Audit Logging: Automatically records register events, login successes and failures, account lockouts, account open/close/freeze/unfreeze actions, deposits, withdrawals, transfers (both succeeded and failed), and manual admin job triggers.	**Should**	US-21, US-22
AUD-02	Audit Entry Structure: Each audit log record stores the timestamp, actor identifier (email or SYSTEM), action code, target entity/account, outcome status (SUCCESS or FAILURE with error code), reason/details, and client IP address. Passwords, hashes, or session tokens are never logged.	**Should**	US-22

Summary of Functional Requirements: 41 Total Functional Requirements | Must Have: 25 Requirements | Should Have: 16 Requirements.

Part 4. Non-Functional Requirements

Non-functional requirements specify the quality attributes, performance targets, operational constraints, and security controls of the system. Part 4A defines system quality attributes; Part 4B defines mandatory security controls.

4A. System Quality Attributes (NFR-01 to NFR-12)

ID	Category	Quality Requirement Specification	Verification Method
NFR-01	Monetary Correctness	All monetary amounts are represented as BigDecimal (with exact scale 2 and RoundingMode.HALF_UP) in Java domain logic and stored as integer whole piasters (BIGINT, where 1 EGP = 100 piasters) in SQLite. Floating-point types (double, float, REAL) are strictly forbidden.	Static code review, SonarLint, JUnit 5 precision unit tests

ID	Category	Quality Requirement Specification	Verification Method
NFR-02	Performance & Latency	On a standard developer workstation running the embedded SQLite database with seed data: REST API endpoints respond in under 500 ms at the 95th percentile (P95) as required by KPI-05, and server-rendered web pages load in under 2.0 seconds.	Postman collection runner latency assertions
NFR-03	Transactional Consistency	Zero partial transfers and zero lost balance updates under application exceptions or concurrent parallel requests. SQLite runs in WAL (Write-Ahead Logging) mode with IMMEDIATE transaction locking.	Parallel withdrawal & transfer concurrency test (TC-C-01)
NFR-04	Auditability	The financial transaction ledger is strictly append-only (UPDATE and DELETE operations on ledger rows are prohibited). All security and administrative events are recorded in the audit log.	Database permission/code review & API integration tests
NFR-05	Testability	System time is obtained exclusively via an injected java.time.Clock bean to allow deterministic testing of lockouts, daily limits, and maturity dates. All interactive HTML elements carry permanent, unique IDs. Seed data and database reset hooks are active only in 'dev' and 'test' profiles.	JUnit 5 Clock mocking & Selenium WebDriver suite
NFR-06	Usability	Forms display clear field-level validation messages next to invalid inputs; global success and error banners use fixed DOM IDs; responsive CSS layout adapts cleanly across desktop (1366px+) and mobile (375px) viewports.	Manual UI testing & Selenium assertions
NFR-07	Browser Compatibility	Full functional and visual compatibility with latest Google Chrome (primary target for Selenium WebDriver automation), plus Mozilla Firefox and Microsoft Edge for manual smoke testing.	Automated Chrome suite & manual cross-browser smoke test
NFR-08	Maintainability	Strict layered architecture (Controller -> Service -> Domain -> Repository). Zero business calculation logic inside controllers or Thymeleaf templates. Every code change requires a peer-reviewed Pull Request.	GitHub PR review checklist & SonarLint / SpotBugs
NFR-09	Portability	The entire system builds and runs out-of-the-box via 'mvn spring-boot:run' (or './mvnw spring-boot:run') on any Windows, Linux, or macOS machine with JDK 17+, requiring zero external database server installation.	Fresh repository clone verification on team laptops
NFR-10	Documentation	OpenAPI 3 / Swagger UI is automatically generated from controller annotations. The repository README documents setup commands (including PowerShell syntax), active profiles, and demo test credentials.	Technical review & fresh-clone onboarding test
NFR-11	Safe Logging	Application logs use structured severity levels (INFO, WARN, ERROR). Plaintext passwords, password hashes, session cookies, and full account numbers (masked to show only the last 4 digits in logs) are never written to log files.	Log output inspection during test runs

ID	Category	Quality Requirement Specification	Verification Method
NFR-12	Accessibility Basics	Every HTML form input is explicitly bound to a <label for='...'> element, all forms are operable via keyboard tab navigation, and text/background color combinations satisfy WCAG AA contrast ratios.	Manual accessibility checklist

4B. Security Requirements & Controls (SEC-01 to SEC-11)

ID	Risk / Threat Addressed	Mandatory Security Control Specification
SEC-01	Broken Access Control	Deny access by default across all routes. Every controller endpoint and service method enforces both role authorization (CUSTOMER vs. ADMIN) and resource ownership on the server.
SEC-02	Insecure Direct Object Reference (IDOR)	When an authenticated customer requests or submits an operation targeting another customer's account, statement, or transaction ID, the server returns HTTP 404 (ACCOUNT_NOT_FOUND)—never HTTP 403—across both Web UI and REST API, preventing account enumeration.
SEC-03	Authentication & Brute-Force Attacks	Passwords are hashed using BCrypt (strength >= 10). Enforces strong password complexity (AUTH-05), 5-attempt / 15-minute account lockout (AUTH-06), generic error messages on login failure, and session ID rotation upon successful authentication (Session Fixation protection).
SEC-04	SQL Injection & Cross-Site Scripting (XSS)	All database access uses parameterized JPA/Hibernate queries (zero string concatenation). All incoming DTOs enforce Jakarta Bean Validation. Thymeleaf templates use standard escaped attributes (th:text) and never render unescaped user input (th:utext).
SEC-05	Cross-Site Request Forgery (CSRF)	Synchronizer CSRF tokens are mandatory and validated on every state-changing web form POST request. Only stateless HTTP Basic REST API endpoints under /api/** are exempted per standard REST security architecture.
SEC-06	Session & Cookie Hijacking	Session cookies are configured with HttpOnly=true, SameSite=Lax, and Secure=true (when running over HTTPS), combined with a strict 15-minute server-side idle session timeout.
SEC-07	Missing Security Headers	Spring Security injects X-Content-Type-Options: nosniff, X-Frame-Options: DENY, Cache-Control: no-store on all authenticated pages, and a restrictive Content-Security-Policy (CSP) disallowing inline scripts.
SEC-08	Sensitive Data Exposure	Zero secrets, credentials, or SQLite database files (.db, .sqlite) committed to Git (.gitignore enforced). Admin bootstrap credentials load from environment variables. Swagger UI is disabled or restricted to ADMIN outside the 'dev' profile. Custom error pages suppress stack traces.
SEC-09	Automated Abuse & Rate Limiting	Account login lockout after 5 failed attempts (AUTH-06) is mandatory (Should). An in-memory rate limiter on money-moving endpoints is defined as an optional enhancement (Could priority, first in descoping order if needed).

ID	Risk / Threat Addressed	Mandatory Security Control Specification
SEC-10	Vulnerable Third-Party Dependencies	Run OWASP Dependency-Check or GitHub Dependabot scanning at least once prior to final delivery. Because Spring Boot 3.5 reached the end of free commercial security updates in June 2026, executing this scan and documenting the known limitation and the upgrade path to Spring Boot 4.1 in the final report are mandatory.
SEC-11	Insufficient Logging & Monitoring	The immutable security audit log (AUD-01, AUD-02) records all failed logins, lockouts, unauthorized access attempts, failed financial transactions, and administrative actions with timestamps and client IP addresses.

Part 5. Complete Business Rules Catalogue (BR-01 to BR-29)

To ensure this document is 100% self-contained, the table below defines all 29 domain business rules referenced across the User Stories and Functional Requirements. All thresholds and rates are externalized in application.yml.

Rule ID	Domain Area	Business Rule Definition & Validation Logic	Violation Error Code
BR-01	Monetary Precision	All transaction and opening amounts must be strictly positive (> 0.00 EGP) and contain at most 2 decimal places (whole piasters). Zero, negative, or 3-decimal amounts are rejected.	**INVALID_AMOUNT**
BR-02	Deposit Limits	A single deposit transaction must be at least 10.00 EGP and must not exceed 100,000.00 EGP per transaction.	**DEPOSIT_LIMIT_EXCEEDED**
BR-03	Currency Standard	The system operates exclusively in Egyptian Pounds (EGP). Multi-currency operations or foreign exchange conversions are out of scope.	**UNSUPPORTED_CURRENCY**
BR-04	Deposit Eligibility	Deposits are permitted only into ACTIVE Savings or Checking accounts owned by the authenticated customer.	**ACCOUNT_NOT_ACTIVE**
BR-05	Single Withdrawal Limit	A single withdrawal or transfer debit transaction must not exceed 70,000.00 EGP.	**TXN_LIMIT_EXCEEDED**
BR-06	Daily & Monthly Withdrawal Velocity	Total withdrawals and outgoing transfer debits (excluding fees) from a single account must not exceed 120,000.00 EGP per calendar day or 400,000.00 EGP per calendar month.	**DAILY_LIMIT_EXCEEDED / MONTHLY_LIMIT_EXCEEDED**
BR-07	Savings Minimum Balance	A Savings account requires a minimum opening deposit of 1,000.00 EGP and must maintain a minimum balance of at least 1,000.00 EGP after any withdrawal or outgoing transfer.	**MIN_BALANCE_VIOLATION**
BR-08	Savings Monthly Interest	Active Savings accounts earn an annual interest rate of 17.00%, calculated monthly as (balance × 0.17 / 12) rounded HALF_UP to the nearest piaster, credited once per calendar month.	**INTEREST_ALREADY_POSTED**

Rule ID	Domain Area	Business Rule Definition & Validation Logic	Violation Error Code
BR-09	Checking Account Opening	A Checking account can be opened with an initial deposit of 0.00 EGP or any positive amount up to the maximum deposit limit. Checking accounts do not earn interest.	**INVALID_OPENING_AMOUNT**
BR-10	Checking Overdraft Limit	A Checking account supports an overdraft facility allowing the balance to drop down to -1,000.00 EGP. Any withdrawal or transfer that pushes the balance below -1,000.00 EGP is refused.	**OVERDRAFT_LIMIT_EXCEEDED**
BR-11	Fixed Deposit Opening Minimum	A Fixed Deposit account requires a minimum initial deposit of 5,000.00 EGP upon creation.	**MIN_OPENING_DEPOSIT_VIOLATION**
BR-12	Fixed Deposit Lock-in Terms	Fixed Deposit accounts must select a valid lock-in term at creation: 12 months (17.00% annual rate) or 36 months (17.75% annual rate). Maturity date is set to opening date + term.	**INVALID_FD_TERM**
BR-13	Fixed Deposit Top-Up Prohibition	No additional deposits are allowed into a Fixed Deposit account after its initial creation.	**FD_DEPOSIT_NOT_ALLOWED**
BR-14	Fixed Deposit Withdrawal Rules	Withdrawals or outgoing transfers from a Fixed Deposit account prior to its maturity date are strictly prohibited. On or after maturity, partial withdrawals are refused; only a full withdrawal of the entire matured balance is permitted.	**FD_NOT_MATURE / FD_PARTIAL_WITHDRAWAL_NOT_ALLOWED**
BR-15	Fixed Deposit Maturity Interest	Upon reaching the maturity date, total interest is calculated as (principal × annual_rate × (term_months / 12)) rounded HALF_UP, and credited exactly once to the Fixed Deposit balance.	**FD_INTEREST_ALREADY_CREDITED**
BR-16	Ledger Immutability	Every financial state change must create an immutable ledger record. Existing ledger records can never be updated or deleted.	**LEDGER_IMMUTABLE_VIOLATION**
BR-17	Running Balance Recording	Each ledger row stores the exact account balance immediately following that transaction ('balance_after') to guarantee deterministic statement rendering.	**BALANCE_MISMATCH**
BR-18	Transaction Reference Format	Every transaction generates a unique alphanumeric reference code (e.g., TXN-YYYYMMDD-XXXXXX) shared across all ledger legs of the same atomic operation.	**DUPLICATE_REFERENCE**
BR-19	Idempotency Protection	When an Idempotency-Key header is supplied on a POST transaction request, the server caches the key and response for 24 hours; duplicate keys return the cached outcome without re-executing.	**IDEMPOTENCY_CONFLICT**

Rule ID	Domain Area	Business Rule Definition & Validation Logic	Violation Error Code
BR-20	Account Status Lifecycle	An account has three statuses: ACTIVE, FROZEN, and CLOSED. Only ACTIVE accounts permit deposits, withdrawals, transfers, or interest accrual. FROZEN accounts can be unfrozen by an ADMIN; CLOSED accounts are terminal and can never be reopened.	**ACCOUNT_FROZEN / ACCOUNT_CLOSED**
BR-21	Account Closure Condition	A customer can close an account only if its status is ACTIVE and its current balance is exactly 0.00 EGP. Accounts with positive balances or negative overdraft balances cannot be closed.	**NON_ZERO_BALANCE**
BR-22	Maximum Accounts Per Customer	A customer may hold at most 5 non-closed accounts (ACTIVE + FROZEN) simultaneously across all account types.	**MAX_ACCOUNTS_EXCEEDED**
BR-23	Account Number Structure	Account numbers are exactly 12 numeric digits: an 11-digit sequential bank prefix followed by 1 Luhn check digit verified before database lookup.	**INVALID_ACCOUNT_NUMBER**
BR-24	Unique Customer Identity & Lockout	Customer email addresses are normalized to lowercase and must be globally unique. Five consecutive failed password attempts lock the user account for 15 minutes.	**DUPLICATE_EMAIL / ACCOUNT_LOCKED**
BR-25	Admin Customer Search Rule	Admin customer name searches trim leading/trailing whitespace, match case-insensitively on any substring, and require at least 2 characters after trimming.	**INVALID_SEARCH_QUERY**
BR-26	Inter-Customer Transfer Fee	Transfers to an account owned by a different customer incur a fee of 0.1% of the transfer amount, rounded HALF_UP, subject to a minimum fee of 0.50 EGP and a maximum fee of 20.00 EGP.	**FEE_CALCULATION_ERROR**
BR-27	Own-Account Transfer Fee Waiver	Transfers between two distinct ACTIVE accounts owned by the same customer incur 0.00 EGP fee and do not generate a FEE ledger entry.	**N/A (Zero Fee)**
BR-28	Transfer Balance & Self-Transfer Check	A transfer to the exact same source account number is rejected. For inter-customer transfers, the source account must have sufficient funds (respecting Savings minimum balance or Checking overdraft) to cover (transfer_amount + transfer_fee).	**SAME_ACCOUNT_TRANSFER / INSUFFICIENT_FUNDS**
BR-29	Transfer Atomic Ledger Triplet	An inter-customer transfer atomically writes three ledger rows within one database transaction: (1) TRANSFER_OUT on source for amount, (2) TRANSFER_IN on destination for amount, and (3) FEE on source for the calculated fee.	**TRANSFER_ATOMICITY_FAILURE**

Part 6. Technical & Operational Specifications

This section consolidates the technical standards (Error Code Catalogue and Concurrency / Money Integrity Architecture) so that developers and testers have all specifications in a single document.

6.1 Standardized Error Code & HTTP Status Catalogue (Supports TXN-07 & SEC-02)

Error Code	HTTP Status	Trigger Condition & Standard User-Facing Message
ACCOUNT_NOT_FOUND	**404 Not Found**	Returned when an account number/ID does not exist OR belongs to another customer (SEC-02 IDOR protection). Message: 'The requested account could not be found.'
INVALID_AMOUNT	**400 Bad Request**	Amount is zero, negative, non-numeric, or has more than 2 decimal places (BR-01). Message: 'Please enter a valid positive amount with up to 2 decimal places.'
MIN_BALANCE_VIOLATION	**422 Unprocessable Entity**	Withdrawal or transfer from a Savings account would leave the balance below 1,000.00 EGP (BR-07, Test Case TC-F-07). Message: 'Savings account balance cannot fall below the 1,000.00 EGP minimum.'
OVERDRAFT_LIMIT_EXCEEDED	**422 Unprocessable Entity**	Withdrawal or transfer from a Checking account would push the balance below -1,000.00 EGP (BR-10). Message: 'Transaction exceeds the -1,000.00 EGP overdraft limit.'
INSUFFICIENT_FUNDS	**422 Unprocessable Entity**	Account balance is insufficient to cover the withdrawal or (transfer amount + fee). Message: 'Insufficient available funds to complete this transaction.'
TXN_LIMIT_EXCEEDED	**422 Unprocessable Entity**	Single withdrawal or transfer exceeds 70,000.00 EGP (BR-05). Message: 'Amount exceeds the maximum single transaction limit of 70,000.00 EGP.'
DAILY_LIMIT_EXCEEDED	**422 Unprocessable Entity**	Cumulative daily withdrawals/transfers exceed 120,000.00 EGP (BR-06). Message: 'Transaction exceeds your remaining daily limit of 120,000.00 EGP.'
MONTHLY_LIMIT_EXCEEDED	**422 Unprocessable Entity**	Cumulative monthly withdrawals/transfers exceed 400,000.00 EGP (BR-06). Message: 'Transaction exceeds your remaining monthly limit of 400,000.00 EGP.'
FD_NOT_MATURE	**422 Unprocessable Entity**	Attempt to withdraw from a Fixed Deposit before its maturity date (BR-14). Message: 'Fixed Deposit funds are locked until the maturity date.'
FD_DEPOSIT_NOT_ALLOWED	**422 Unprocessable Entity**	Attempt to deposit additional funds into an existing Fixed Deposit account (BR-13). Message: 'Additional deposits are not permitted for Fixed Deposit accounts.'
ACCOUNT_FROZEN	**423 Locked / 422**	Attempt to transact on a FROZEN account (BR-20). Message: 'This account is currently frozen. Please contact bank administration.'

Error Code	HTTP Status	Trigger Condition & Standard User-Facing Message
ACCOUNT_CLOSED	**422 Unprocessable Entity**	Attempt to transact on or reopen a CLOSED account (BR-20). Message: 'This account is permanently closed and cannot accept transactions.'
NON_ZERO_BALANCE	**422 Unprocessable Entity**	Attempt to close an account whose balance is not exactly 0.00 EGP (BR-21). Message: 'Account balance must be 0.00 EGP before closing.'
MAX_ACCOUNTS_EXCEEDED	**422 Unprocessable Entity**	Customer attempts to open a 6th non-closed account (BR-22). Message: 'Maximum limit of 5 active/frozen accounts per customer reached.'
SAME_ACCOUNT_TRANSFER	**400 Bad Request**	Source and destination account numbers are identical (BR-28). Message: 'Source and destination accounts cannot be the same.'
INVALID_ACCOUNT_NUMBER	**400 Bad Request**	Account number fails 12-digit length or Luhn check-digit validation (ACC-07, BR-23). Message: 'Invalid 12-digit account number format.'
DUPLICATE_EMAIL	**409 Conflict**	Registration attempted with an email that already exists (BR-24). Message: 'An account with this email address is already registered.'

6.2 Concurrency, Atomicity & Piaster Storage Architecture (Supports TXN-05, TXN-06 & NFR-01)

Architectural Pillar	Implementation Specification & Verification Rule
Exact Monetary Representation (Piaster Storage)	To eliminate IEEE 754 floating-point rounding errors in SQLite, all balances, transaction amounts, and fees are stored in SQLite columns of type BIGINT representing whole piasters (1 EGP = 100 piasters; e.g., 1,000.50 EGP is stored as 100050). In the Java service and domain layers, values are converted via a JPA AttributeConverter into BigDecimal with scale 2 and RoundingMode.HALF_UP. Basis points (integer) are used for interest and fee rate configurations.
SQLite Concurrency & WAL Configuration	Because SQLite supports a single writer at a time, the datasource is configured with Write-Ahead Logging (PRAGMA journal_mode=WAL;), a busy timeout of 5,000 ms (PRAGMA busy_timeout=5000;), immediate write lock acquisition (BEGIN IMMEDIATE), and a single-connection HikariCP pool (maximum-pool-size=1) to serialize write transactions deterministically without throwing 'SQLITE_BUSY / database is locked' errors.
Atomic Transaction Rollback Boundary	Every service method that modifies balances (@Transactional(rollbackFor = Exception.class)) executes all validation checks, balance updates, and append-only ledger insertions within a single database transaction. Any business exception (unchecked DomainException) triggers a complete rollback, guaranteeing that half-finished transfers can never occur.

Architectural Pillar	Implementation Specification & Verification Rule
Parallel Concurrency Verification (Test TC-C-01)	The test suite includes an automated multi-threaded concurrency test (TC-C-01) that fires simultaneous withdrawal and transfer requests against a single account whose balance allows only one operation to succeed, verifying that exactly one succeeds, the other fails with INSUFFICIENT_FUNDS or MIN_BALANCE_VIOLATION, and the final balance equals the exact ledger sum.